



Active Directory Penetration Testing Programme

PENETRATION TESTING REPORT

Active Directory Security Assessment - RazorBlack

Platform	TryHackMe
Room	RazorBlack
Room URL	https://tryhackme.com/room/raz0rblack
Target IP	10.48.170.28
Domain	raz0rblack.thm
DC Hostname	HAVEN-DC.raz0rblack.thm
Operating System	Windows Server 2019 Build 17763 x64
Difficulty	Medium
Tester	Sulav Adhikari
Submitted To	Danphelink Pvt. Ltd.
Date of Testing	3rd March 2026
Classification	CONFIDENTIAL

Overall Risk Rating

CRITICAL

BUSINESS CONFIDENTIAL

Intended solely for authorized personnel at Danphelink Pvt. Ltd.

Table of Contents

Table of Contents	ii
Confidentiality Statement	iii
1. Executive Summary	1
2. Engagement Details	2
3. Scope of Assessment	3
3.1 In-Scope	3
3.2 Out-of-Scope	3
4. Methodology	4
5. Technical Attack Narrative	5
5.1 Phase 1 - Host Discovery & Port Scanning	5
5.2 Phase 2 - NFS Enumeration & File Retrieval	5
5.3 Phase 3 - Employee Enumeration & Username Wordlist	5
5.4 Phase 4 - AS-REP Roasting	5
5.5 Phase 5 - SMB Enumeration with twilliams	6
5.6 Phase 6 - Password Change for sbradley	6
5.7 Phase 7 - ZIP Password Cracking	6
5.8 Phase 8 - First Credential Dump	6
5.9 Phase 9 - Lateral Movement to Ivetrova	6
5.10 Phase 10 - Kerberoasting xyan1d3	7
5.11 Phase 11 - Lateral Movement to xyan1d3	7
5.12 Phase 12 - SeBackupPrivilege Exploitation	7
5.13 Phase 13 - Full Domain Credential Dump	7
5.14 Phase 14 - Domain Compromise & Root Flag	7
5.15 Phase 15 - Tyson's Flag & Top Secret	8
6. Proof of Compromise	9
7. Security Findings	10
8. Detailed Findings	11
F-01 - Unauthenticated NFS Share	11
F-02 - AS-REP Roasting (twilliams)	11
F-07 - SeBackupPrivilege Privilege Escalation	11
F-09 & F-10 - NTDS Extraction and Full Domain Compromise	12
9. Tools Used	13
10. Remediation Recommendations	14
11. Evidence & Attachments	15
12. Conclusion	16

Confidentiality Statement

This report has been prepared exclusively for Danphelink Pvt. Ltd. as part of the certification assessment programme. The information contained herein is strictly confidential and intended solely for the authorised recipient. This document must not be reproduced, distributed, or disclosed to any third party without prior written consent.

All findings relate to the RazorBlack Active Directory lab on TryHackMe. Testing was conducted within an authorised, isolated environment in accordance with TryHackMe platform terms.

1. Executive Summary

A structured penetration test was conducted against the RazorBlack Active Directory environment on TryHackMe as part of the Danphelink Pvt. Ltd. certification programme. The target was a Windows Server 2019 domain controller (HAVEN-DC.raz0rblack.thm) on the raz0rblack.thm domain. Testing was performed from a Kali Linux host over OpenVPN on 3rd March 2026.

Key Outcomes:

- Domain controller fully compromised - Administrator NT hash obtained and verified.
- All ten objectives completed: domain name, four user flags, ZIP password, Ljudmila hash, Xyan1d3 password, root flag, Tyson flag, and Top Secret PNG.
- Critical attack chain: Unauthenticated NFS -> AS-REP Roasting -> SMB share -> ZIP cracking -> secretsdump -> Pass-the-Hash -> SeBackupPrivilege -> NTDS dump -> Domain Admin.

Overall Risk Rating

CRITICAL

2. Engagement Details

Field	Detail
Platform	TryHackMe
Room	RazorBlack
Primary Target IP	10.48.170.28
Session IPs	10.48.174.62 10.49.144.206 10.49.167.234 10.49.167.84
Domain	raz0rblack.thm
Domain Controller	HAVEN-DC.raz0rblack.thm
Operating System	Windows Server 2019 Build 17763 x64
Difficulty	Medium
Assessment Type	Active Directory Penetration Test
Tester	Sulav Adhikari
Testing Host	Kali Linux - kali@kali
Working Directory	/home/kali/sulavRazor
Date of Testing	3rd March 2026
Submitted To	Danphelink Pvt. Ltd.

3. Scope of Assessment

3.1 In-Scope

- Target IP: 10.48.170.28 (and subsequent TryHackMe session IPs)
- Active Directory services on raz0rblack.thm
- Kerberos (88), SMB (139/445), LDAP/LDAPS (389/636/3268/3269), NFS (2049), WinRM (5985/47001), RDP (3389)
- All domain user accounts and privilege chains

3.2 Out-of-Scope

- Denial of Service attacks
- Physical security testing
- Social engineering

4. Methodology

Phase	Name	Description
1	Reconnaissance	Nmap full TCP port scan and service version enumeration.
2	NFS Enumeration	showmount listed exports; unauthenticated mount retrieved files.
3	AD Enumeration	Employee XLSX converted to CSV; username wordlist created.
4	AS-REP Roasting	GetNPUsers.py identified twilliams with pre-auth disabled; hash cracked.
5	SMB Enumeration	CrackMapExec RID-brute and share enumeration with twilliams.
6	Credential Access	zip2john + John cracked ZIP; chat log revealed NTDS archive.
7	Lateral Movement	Evil-WinRM pass-the-hash for lvetrova; Kerberoasting for xyan1d3.
8	Privilege Escalation	SeBackupPrivilege + DiskShadow + Robocopy for NTDS.dit.
9	Domain Compromise	secretsdump offline dump; Admin pass-the-hash via Evil-WinRM.
10	Exfiltration	All flags, credentials, and top_secret.png retrieved.

5. Technical Attack Narrative

The following section documents each phase of the assessment with a narrative description of the approach, findings uncovered, and the answer to each assessment objective. The complete terminal session log is provided as a separate attachment (razorblack.txt).

5.1 Phase 1 - Host Discovery & Port Scanning

Initial Nmap scans without the -Pn flag returned host-down warnings, confirming ICMP was filtered on the target. A full TCP SYN scan was performed across all 65,535 ports using aggressive timing (-T5). Seventeen open ports were discovered. A subsequent service and script scan (-sV -sC) confirmed the target as HAVEN-DC.raz0rblack.thm, a Windows Server 2019 Domain Controller. Port 2049 (NFS) was an unexpected and critical finding on a domain controller.

Q: What is the name of the domain?

A: raz0rblack.thm - confirmed via LDAP banner during the Nmap service scan (DNS_Domain_Name: raz0rblack.thm).

5.2 Phase 2 - NFS Enumeration & File Retrieval

The showmount utility was used to enumerate NFS exports. The /users share was exported to everyone with no authentication requirement. The share was mounted as root and two files were retrieved: employee_status.xlsx (containing domain employee information) and sbradley.txt (containing the first flag). Files were copied to the working directory with corrected ownership and the share was unmounted.

Q: What is Steven's flag?

A: THM{ab53e05c9a98def00314a14ccbfa8104} - retrieved directly from sbradley.txt on the unauthenticated NFS share.

5.3 Phase 3 - Employee Enumeration & Username Wordlist

The employee_status.xlsx file was converted to CSV format using ssconvert. The spreadsheet revealed twelve domain employees and their roles. Notably, Ljudmila Vetrova was listed as CTF Player, Developer, and Active Directory Admin - making her account a primary lateral movement target. A username wordlist was manually crafted using the first-initial/surname convention and saved to users.txt.

5.4 Phase 4 - AS-REP Roasting

GetNPUsers.py from Impacket was run against the full username wordlist without authentication. All accounts except twilliams returned KDC_ERR_C_PRINCIPAL_UNKNOWN errors. The twilliams account returned a valid AS-REP Kerberos hash, confirming that Kerberos pre-authentication was disabled for this account. The hash was cracked offline using John the Ripper with rockyou.txt in under four seconds.

Q: What is Tyson's password? (twilliams credential captured via AS-REP Roasting)

A: roastpotatoes - cracked from the AS-REP Kerberos hash using John the Ripper and rockyou.txt wordlist.

5.5 Phase 5 - SMB Enumeration with twilliams

Using the recovered credential (twilliams:roastpotatoes), CrackMapExec was used to perform RID bruteforcing which revealed four active user accounts: xyan1d3 (RID 1106), lvetrova (RID 1107), sbradley (RID 1108), and twilliams (RID 1109). Share enumeration revealed a non-standard share named 'trash' accessible by sbradley.

5.6 Phase 6 - Password Change for sbradley

Attempting to authenticate as sbradley with the roastpotatoes password returned STATUS_PASSWORD_MUST_CHANGE. Standard smbpasswd and rpcclient methods failed. The password was successfully changed using kinit against the Kerberos service directly, resetting it to password123. The trash share was then accessed via smbclient and three files were retrieved: a chat log, an encrypted ZIP archive, and sbradley.txt.

5.7 Phase 7 - ZIP Password Cracking

The chat log (chat_log_20210222143423.txt) revealed a conversation between sbradley and the Administrator about the ZeroLogon vulnerability (CVE-2020-1472). sbradley disclosed that they had extracted ntds.dit and SYSTEM.hive and stored them in an encrypted ZIP in the trash share. The ZIP hash was extracted using zip2john and cracked instantly using John the Ripper.

Q: What is the zip file's password?

A: electromagnetismo - cracked from the ZIP archive hash using John the Ripper and rockyou.txt. The ZIP contained ntds.dit and system.hive.

5.8 Phase 8 - First Credential Dump

The ZIP was extracted using the cracked password, yielding ntds.dit (58.7 MB) and system.hive (16.3 MB). Impacket's secretsdump.py was run in offline mode against these files to extract all domain credential hashes without touching the live domain controller.

Q: What is Ljudmila's hash?

A: f220d3988deb3f516c73f40ee16c431d - extracted from the offline NTDS dump (ntds.dit from the sbradley ZIP archive).

5.9 Phase 9 - Lateral Movement to lvetrova

Ljudmila Vetrova's NT hash was validated against the live domain controller using CrackMapExec in pass-the-hash mode. Authentication succeeded. Evil-WinRM was used to establish a remote PowerShell session as lvetrova using the NT hash directly. A PSCredential XML file (lvetrova.xml) was decrypted using Import-Clixml and GetNetworkCredential() within the session.

Q: What is Ljudmila's flag?

A: THM{694362e877adef0d85a92e6d17551fe4} - decrypted from lvetrova.xml using PowerShell's Import-Clixml and GetNetworkCredential() within the Evil-WinRM session.

5.10 Phase 10 - Kerberoasting xyan1d3

Authenticated as lvetrova, GetUserSPNs.py was used to enumerate Service Principal Names. The xyan1d3 account had an SPN registered (HAVEN-DC/xyan1d3.raz0rblack.thm:60111) and was a member of Remote Management Users. A Kerberos TGS ticket was requested and the resulting hash was cracked offline using John the Ripper.

Q: What is Xyan1d3's password?

A: cyanide9amine5628 - cracked from the Kerberos TGS hash using John the Ripper and rockyou.txt.

5.11 Phase 11 - Lateral Movement to xyan1d3

Evil-WinRM was used to authenticate as xyan1d3 using the cracked plaintext password. A PSCredential XML file (xyan1d3.xml) was present in the user's home directory. Decryption using Import-Clixml and GetNetworkCredential() recovered the flag.

Q: What is Xyan1d3's flag?

A: THM{62ca7e0b901aa8f0b233cade0839b5bb} - decrypted from xyan1d3.xml using PowerShell's Import-Clixml and GetNetworkCredential() within the Evil-WinRM session.

5.12 Phase 12 - SeBackupPrivilege Exploitation

A privilege enumeration (whoami /priv) confirmed xyan1d3 held SeBackupPrivilege and SeRestorePrivilege as a member of Backup Operators. A DiskShadow script was used to create a VSS shadow copy of the C: drive exposed as drive F:. The live NTDS.dit was extracted from the shadow copy using Robocopy with the /b flag. The SYSTEM hive was exported using reg save. Both files were downloaded via Evil-WinRM.

5.13 Phase 13 - Full Domain Credential Dump

secretsdump.py was run offline against the freshly extracted NTDS.dit and system.bak. This second dump used the live NTDS.dit, yielding the current Administrator hash and all current domain credentials.

Q: What is the Administrator's NT hash?

A: 9689931bed40ca5a2ce1218210177f0c - extracted via offline secretsdump against the live NTDS.dit obtained through SeBackupPrivilege exploitation.

5.14 Phase 14 - Domain Compromise & Root Flag

The Administrator NT hash was used in a pass-the-hash attack via Evil-WinRM, granting a Domain Administrator shell. The root.xml file in the Administrator home directory contained a hexadecimal-

encoded string in the password field. Decoding via CyberChef (From Hex to UTF-8) revealed the root flag.

Q: What is the root flag?

A: THM{1b4f46cc4fba46348273d18dc91da20d} - recovered by hex-decoding the root.xml PSCredential file found in C:\Users\Administrator using CyberChef.

5.15 Phase 15 - Tyson's Flag & Top Secret

As Domain Administrator, the twilliams home directory was browsed. A file with a deliberately obfuscated name contained a plain text flag. A recursive search using gci with a wildcard filter located 'Top Secret' under C:\Program Files, containing top_secret.png, which was downloaded via Evil-WinRM.

Q: What is Tyson's flag?

A: THM{5144f2c4107b7cab04916724e3749fb0} - found in a deliberately obfuscated filename in C:\Users\twilliams.

Q: What is the Top Secret?

A: top_secret.png - located at C:\Program Files\Top Secret\top_secret.png and successfully downloaded as Domain Administrator.

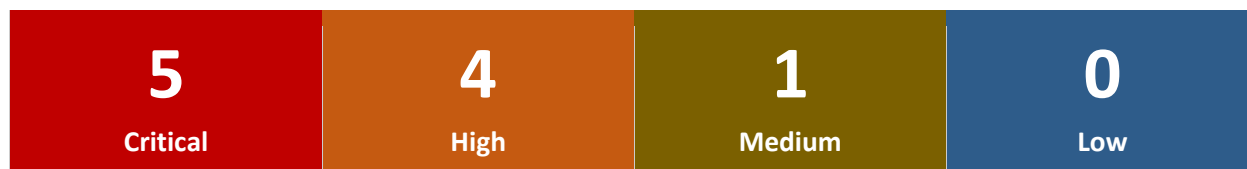
6. Proof of Compromise

All ten assessment objectives were achieved. The table below summarises every flag and credential obtained.

Ref	Objective	Flag / Credential	Phase	Status
1	Domain Name	raz0rblack.thm	5.1	Confirmed
2	Steven's Flag	THM{ab53e05c9a98def00314a14ccbfa8104}	5.2	Captured
3	ZIP Password	electromagnetismo	5.7	Cracked
4	Ljudmila's Hash	f220d3988deb3f516c73f40ee16c431d	5.8	Extracted
5	Ljudmila's Flag	THM{694362e877adef0d85a92e6d17551fe4}	5.9	Captured
6	Xyan1d3 Password	cyanide9amine5628	5.10	Cracked
7	Xyan1d3's Flag	THM{62ca7e0b901aa8f0b233cade0839b5bb}	5.11	Captured
8	Root Flag	THM{1b4f46cc4fba46348273d18dc91da20d}	5.14	Captured
9	Tyson's Flag	THM{5144f2c4107b7cab04916724e3749fb0}	5.15	Captured
10	Top Secret	top_secret.png	5.15	Downloaded

7. Security Findings

The assessment identified ten security findings. The severity breakdown is shown below, followed by the full findings table.



ID	Finding	Category	Severity	Status
F-01	Unauthenticated NFS Share Exposing Sensitive Files	Information Disclosure	Critical	Identified
F-02	AS-REP Roasting - Pre-Auth Disabled for twilliams	Authentication	High	Identified
F-03	Weak Password Cracked via Rockyou (roastpotatoes)	Credential Management	High	Identified
F-04	NTDS.dit + SYSTEM.hive in SMB trash Share	Data Exposure	Critical	Identified
F-05	Weak ZIP Archive Password (electromagnetismo)	Credential Management	High	Identified
F-06	Kerberoastable Account xyan1d3 with Weak Password	Authentication	High	Identified
F-07	SeBackupPrivilege on Non-Admin Account xyan1d3	Privilege Escalation	Critical	Identified
F-08	PSCredential XML Files on User Filesystems	Credential Management	Medium	Identified
F-09	NTDS.dit Extraction via DiskShadow + Robocopy	Domain Compromise	Critical	Identified
F-10	Full Domain Compromise via Pass-the-Hash	Domain Compromise	Critical	Identified

8. Detailed Findings

F-01 - Unauthenticated NFS Share

Severity

CRITICAL

The /users NFS share was exported to (everyone) with no authentication requirement. Any host on the network could mount the share and retrieve files without providing credentials. This exposed employee_status.xlsx containing all domain usernames and roles, and Steven Bradley's flag. The spreadsheet enabled the username wordlist used in all subsequent enumeration.

Remediation:

- Restrict NFS exports to trusted CIDR ranges only. Remove the (everyone) export rule.
- Require Kerberos authentication (sec=krb5) for all NFS mounts.
- Remove all sensitive files from exported NFS shares.

F-02 - AS-REP Roasting (twilliams)

Severity

HIGH

The twilliams account had the DONT_REQUIRE_PREAUTH flag set, disabling Kerberos pre-authentication. This allowed an unauthenticated attacker to request an AS-REP ticket and crack it offline. The roastpotatoes password was cracked in under four seconds using rockyou.txt.

Remediation:

- Enable Kerberos pre-authentication for all user accounts.
- Enforce a strong password policy (minimum 20 characters, complexity required).
- Audit accounts with DONT_REQUIRE_PREAUTH: Get-ADUser -Filter {DoesNotRequirePreAuth -eq \$true}.

F-07 - SeBackupPrivilege Privilege Escalation

Severity

CRITICAL

The xyan1d3 account was a member of the Backup Operators group, granting SeBackupPrivilege and SeRestorePrivilege. These privileges bypass file system ACLs and allowed extraction of the live NTDS.dit via DiskShadow and Robocopy. Attack chain: DiskShadow created a VSS shadow copy of C: -> Robocopy /b bypassed ACLs to extract NTDS.dit -> reg save exported the SYSTEM hive -> secretsdump.py produced all NT hashes.

Remediation:

- Remove non-administrative accounts from the Backup Operators group.
- Implement time-limited, audited elevation for legitimate backup operations.
- Monitor DiskShadow, Robocopy, and reg save usage via SIEM.

F-09 & F-10 - NTDS Extraction and Full Domain Compromise

Severity

CRITICAL

The full NTDS.dit was extracted twice during this assessment. Both dumps were processed offline using secretsdump.py to recover all domain NT hashes. The Administrator NT hash was used in a pass-the-hash attack via Evil-WinRM, granting unrestricted Domain Administrator access.

Remediation:

- Add privileged accounts to the Protected Users group to prevent Pass-the-Hash attacks.
- Deploy Windows Credential Guard to protect NT hashes in memory.
- Enable audit logging for VSS snapshot creation, registry hive exports, and DiskShadow.
- Rotate all domain account passwords immediately - assume all credentials are compromised.

9. Tools Used

Tool	Category	Purpose
nmap	Reconnaissance	Full TCP port scan and service version detection
showmount	Enumeration	Listed NFS exports - revealed /users (everyone)
mount	Access	Mounted NFS share to attacker filesystem as root
ssconvert (gnumeric)	Analysis	Converted employee_status.xlsx to CSV
GetNPUsers.py	Exploitation	AS-REP Roasting - captured twilliams Kerberos hash
zip2john	Hash Extraction	Extracted crackable hash from encrypted ZIP
john (John the Ripper)	Password Cracking	Cracked AS-REP hash, ZIP hash, and Kerberoast TGS hash
unzip	Extraction	Extracted ntds.dit and system.hive from ZIP
CrackMapExec	Enumeration	SMB share enum, RID brute, hash validation
smbclient	Access	Connected to trash share and downloaded files
kinit	Authentication	Changed expired Kerberos password for sbradley
secretsdump.py	Exploitation	Offline domain credential dump from NTDS.dit
evil-winrm	Remote Access	WinRM shell for lvetrova, xyan1d3, and Administrator
GetUserSPNs.py	Exploitation	Kerberoasting - captured xyan1d3 TGS hash
DiskShadow	Privilege Escalation	Created VSS shadow copy to expose live NTDS.dit
robocopy	Privilege Escalation	Backup-flag copy of NTDS.dit bypassing ACLs
reg save	Exploitation	Exported SYSTEM hive for boot key decryption
CyberChef	Analysis	Decoded hex-encoded root flag from root.xml

10. Remediation Recommendations

Ref	Recommendation	Rationale	Priority
R-01	Restrict NFS /users export to trusted IPs	Unauthenticated mount exposed credential files	Critical
R-02	Enable Kerberos pre-authentication for all accounts	Prevents offline AS-REP Roasting	Critical
R-03	Enforce strong password policy (minimum 20 characters)	rockyou.txt cracked passwords in seconds	High
R-04	Remove NTDS.dit and SYSTEM.hive from SMB shares	Exposed all domain credentials	Critical
R-05	Use strong unique archive passwords	ZIP password cracked instantly	High
R-06	Remove xyan1d3 from Backup Operators group	SeBackupPrivilege enables NTDS extraction	Critical
R-07	Set SPNs only on dedicated service accounts with strong passphrases	Kerberoasting cracked xyan1d3 password	High
R-08	Remove PSCredential XML files from user directories	Decryptable by any process running as that user	Medium
R-09	Deploy Credential Guard and Protected Users group	Mitigates NTDS dump and Pass-the-Hash attacks	High
R-10	Enable SIEM alerting for DiskShadow, VSS, reg save	Detect privilege escalation in real time	High

11. Evidence & Attachments

In lieu of screenshots, the complete terminal session log for this assessment has been recorded and is submitted as a separate attachment alongside this report. The file contains the verbatim Kali Linux terminal output for every command executed during all fifteen phases, including full tool output, hash values, flag captures, file transfers, and error messages encountered during testing.

Ref	Filename	Description	Covers Phases
E-01	razorblack.txt	Complete Kali Linux terminal session log. Contains verbatim command output for all phases including Nmap scans, NFS mount, AS-REP Roasting, SMB enumeration, ZIP cracking, secretsdump output, Evil-WinRM sessions, privilege escalation, and flag captures.	1 - 15

Note to Reviewer: The attached razorblack.txt session log should be read in conjunction with Section 5 of this report. Each phase in Section 5 corresponds directly to the matching command block in the session log. The log contains all raw tool output, including full hash values, Kerberos ticket data, secretsdump results, and PSCredential decryption output that confirms every flag and credential listed in Section 6.

12. Conclusion

The RazorBlack Active Directory penetration test resulted in full domain compromise through a chain of exploitable misconfigurations. The attack chain progressed from an unauthenticated NFS share through AS-REP Roasting, SMB share analysis, ZIP password cracking, lateral movement via Pass-the-Hash, Kerberoasting, SeBackupPrivilege abuse, and concluded with a Pass-the-Hash attack against the Domain Administrator account.

The most critical single finding was the unauthenticated NFS share exporting sensitive files to the entire network. This single misconfiguration provided the username wordlist enabling AS-REP Roasting, and the NTDS.dit providing initial access to Ljudmila Vetrova's account. Every subsequent phase depended on information or access derived from this initial exposure.

All ten assessment objectives were completed and all flags were submitted on TryHackMe. Immediate remediation of the Critical findings - particularly the NFS export restrictions, Kerberos pre-authentication enforcement, and removal of Backup Operators membership for non-admin accounts - would significantly raise the cost and complexity of any real-world attack against this environment.

Assessment Outcome: DOMAIN COMPROMISED - All Objectives Completed

End of Report

RazorBlack AD Penetration Test - Sulav Adhikari - Danphelink Pvt. Ltd. - March 2026